

09 — Lab Takeaways

Exam-useful findings from DFIR classroom labs (detection focus)

Educational / Defensive DFIR Study Notes

LEARNING OBJECTIVES

- Recall Event IDs, tools, and prove-X points from Labs 1–4
- Map sandbox, triage, cred-dump detection, persistence, memory, web, and exfil findings
- Keep Observed / Inferred / Unresolved certainty labels
- Never treat this sheet as an attack guide — detection and artifacts only

SCOPE REMINDER

- This material covers detection, artifacts, and incident response only.
- Attacker actions are phrased as 'adversaries may...' then pivot to evidence.
- Tool/command names appear as IOC strings / exam knowledge — not how-to guides.

Lab 1 — Sandboxing → Malware analysis

- **Tool:** Hybrid Analysis; optional FLOSS when strings are sparse.
- **Workflow:** verdict → expand Malicious Indicators → host IOCs → network IOCs → enrich → triage write-up; export STIX/MISP/JSON + PCAP + ATT&CK.
- **Host IOC:** PE under %APPDATA%\Microsoft\DeviceSync\agent-*.tmp; WMI / service / COM hijack signals; injection / reflective load.
- **Network:** Dead-drop resolver **T1102.001** (Pastebin raw URL over HTTPS). **403 still proves the attempt**; hunt URL path + non-browser process, not Pastebin reputation.
- **Exam:** thin Malicious list + strong suspicion = unresolved (escalate). Classic lineage: WINWORD → cmd/powershell.

Lab 2-1 — Triage collection

- Order of volatility: **memory before disk**.
- SANS/KAPE-style triage keeps a live DC in service vs full image; still hash and custody.
- Collect Registry + EVTX; document gaps (Users\Public staging may be omitted).
- Dirty SOFTWARE hive: replay transaction logs = Yes; load dirty hive = Yes.

Lab 2-2 — Credential dumping (detection only)

NO ATTACK RECIPES

- Tool names and cmdline fragments appear only as detection IOCs.
- No passwords, NTLM hashes, or dump contents from labs are recorded here.

- **4688:** dump-tool patterns targeting lsass.exe (ProcDump-style / comsvcs MiniDump-style hunt strings).
- Credential-tool module strings (e.g. sekurlsa::...) = hunt strings in cmdline / Script Block logs.
- **No 4104** when dump used a native EXE is expected — Script Block only sees PowerShell.
- **DCSync:** 4662 replication GUIDs + non-machine\$ subject + tight burst; correlate 4624 Type 3 for source IP ≠ DC; krbtgt involvement ⇒ domain master-key risk.

Lab 2-3 — Persistence

Mechanism	Key Event / artifact	Note
Permanent WMI	5861 / 5859; WmiPrvSE parent	Filter+Consumer+Binding in CIM repo
Scheduled task	4698 create; Op 129 exec	Suspicious location / Public payload
BITS job	BITS DB / 4688 bitsadmin	HTTP IP may be uncorroborated
Run key	HKLM Run; 4688 at logon	Easiest to find

- Four mechanisms often serve **one** payload under Users\Public.
- Registered vs fired: parent of 4688. Absence of a malicious service is still a finding.
- Remediate all layers together or a survivor restores the payload.

Lab 3 — Memory forensics

- **Volatility 3:** WINWORD delivery → Public drops (GUP.exe, libcurl.dll); rundll32 ...libcurl.dll,#52 (**T1218.011**).
- Reflective load: malfind RWX private + MZ (**T1620**). malfind = leads — carve/parse PE. Empty hexdump = pages not in capture.
- Loopback relay: LISTENING 127.0.0.1:9090 (network sensors miss). CLOSED external socket with no owner = uncorroborated IOC.
- Certainty: Observed / Inferred / Unresolved. Tag ATT&CK only for what the image shows.

Lab 4-1 — Web attacks / webshell

- Join WAF ↔ IIS on **request ID** (d4rid), not nearest timestamp. Blocked probe → zero IIS rows (absence with a cause).

- Decode-then-match gateway order can miss encoded probes (control limit).
- Prove execution: w3wp → cmd/powershell **4688** + matching request marker + app exit success — not HTTP 200 alone.
- Hayabusa: Suspicious Process By Web Server Process. Watch writable uploads for .aspx.

Lab 4-2 — Data exfiltration

- Separate retained Day-2 persistence from new staging by date/time.
- Hayabusa: 4688 row count ≠ Proc Exec event count. Burst vs quiet window as a rate; launch rate ≠ DNS packet rate.
- Encrypted archive staging: hash members vs files; compressed size ≠ source bytes. Reconstruct DNS chunks offline.
- Upload intent: curl + PowerShell history (two independent sources). Keep staged / compressed / received / delivered separate.

QUICK REFERENCE

- Memory before disk; 4688 cmdline is king for execution
- DCSync = 4662 + 4624 Type 3; webshell = w3wp child + request ID join
- malfind leads ≠ conclusions; loopback C2 is invisible to network sensors
- Dead-drop 403 still proves attempt; WMI+task+BITS+Run → one payload
- Lab packs stay out of the public study repo — takeaways only